

Dependency & Supply-Chain Audit Trail — vulnerable-invoice-service

Generated: 2026-06-19T07:30:00Z | Run SHA: 61ed8c3 | Branch: fix/depSCAN-20260619-070527 | Health Score: **92 / 100 (Grade A)**

Executive Summary

Before this run: 73 CVEs across 9 vulnerable dependencies, 2 supply-chain BLOCK findings (typosquat + insecure HTTP repository), Health Score **0 / 100 (Grade D)**.

After auto-remediation: 72 CVEs resolved, 2 supply-chain risks eliminated. 1 HIGH finding remains with no upstream fix available (MAJOR_REVIEW raised). Health Score **92 / 100 (Grade A)**.

- 24 dependencies scanned across 1 Maven module
- 16 CRITICAL CVEs found in Stage 1 — all resolved ✓
- 51 HIGH CVEs found in Stage 1 — all resolved ✓
- 6 MEDIUM CVEs found in Stage 1 — all resolved ✓
- 2 supply-chain BLOCKs : typosquatted coordinate + insecure HTTP repository — both removed ✓
- 1 HIGH CVE remains in mysql-connector-java:8.0.33 — upstream fix.state=not-fixed (MAJOR_REVIEW)
- Gate outcome: **PASS** (no unresolved CRITICAL; 1 HIGH with no available fix = accepted residual)

Health Score Breakdown

Factor	Deduction
Unresolved CRITICAL CVEs (0 × -15)	-0
Unresolved HIGH CVEs (1 × -8, no fix available)	-8
Unresolved MEDIUM CVEs (0 × -2)	-0
Supply-chain BLOCK findings (0 × -10)	-0
Outdated major-version deps (0 × -3)	-0
Score	92 / 100

Trend vs. start of run (SHA 61ed8c3): 0 → 92 (+92 Δ) · Grade D → Grade A

Stage 1 — Dependency Scan

Scanned: 2026-06-19T07:08:00Z · SHA 61ed8c3

Severity	Vulnerable Deps	CVEs
CRITICAL	4	73 total

HIGH	2	(see risk report)
MEDIUM	3	(see risk report)
Totals	9	73

Supply-chain alerts (pre-remediation):

BLOCK

TYPOSQUATTED_DEPENDENCY — com.fastxml.jackson.core:jackson-databind:2.9.8 GroupId missing "er", impersonates com.fasterxml.jackson.core . Unresolvable from Maven Central — supply-chain confusion attack vector. → Removed in Stage 3.

BLOCK

INSECURE_REPOSITORY — http://insecure-mirror.example.net/maven2 Plain-HTTP mirror declaration; MITM attack vector on dependency downloads. → Removed in Stage 3.

Stage 2 — Risk Scoring (Top 10 by Risk Score)

Rank	Coordinate	Risk Score	Band	Top CVE	CVSS	Fix Version
1	log4j-core:2.14.1	9.0	CRITICAL	CVE-2021-44228 (Log4Shell)	10.0	2.25.4
2	jackson-databind:2.9.8	8.4	CRITICAL	CVE-2019-14379	9.8	2.14.0
3	log4j-api:2.14.1	8.0	CRITICAL	CVE-2026-34479	7.5	2.25.4
4	mysql-connector-java:8.0.30	8.0	CRITICAL	CVE-2023-22102	8.3	8.0.33
5	protobuf-java:3.19.4	6.9	HIGH	CVE-2024-7254	7.5	3.25.3
6	guava:24.1.1-jre	6.6	HIGH	CVE-2023-2976	7.1	32.1.1-jre
7	jackson-annotations:2.9.0	5.7	MEDIUM	CVE-2018-1000873	6.5	2.14.0
8	commons-io:2.4	5.7	MEDIUM	CVE-2021-29425	4.8	2.15.1
9	commons-lang3:3.4	5.3	MEDIUM	CVE-2025-48924	5.3	3.18.0
10	com.fastxml... (typosquat)	3.4	MEDIUM	—	—	REMOVE

Stage 3 — Auto-Remediation

Branch: fix/depSCAN-20260619-070527 · Commits: 2

Coordinate	Old → New	Type	CVEs Cleared
com.fastxml.jackson.core:jackson-databind	2.9.8 → REMOVED	Supply-chain removal	typosquatted coordinate
insecure-mirror.example.net	(repo entry) → REMOVED	Supply-chain removal	MITM attack vector
log4j-core + log4j-api	2.14.1 → 2.25.4	Lockstep minor	CVE-2021-44228 (10.0), CVE-2021-45046, CVE-2026-34479, GHSA-3pxv-7cmr-fjr4, GHSA-vc5p-v9hr-52mj, GHSA-6hg6-v5c8-fphq
jackson-databind	2.9.8 → 2.14.0	Minor	CVE-2019-14379 (9.8), CVE-2019-12384, CVE-2020-36518, + 51 others

mysql-connector-java	8.0.30 → 8.0.33	Patch	CVE-2023-22102 (8.3)
guava	24.1.1-jre → 32.1.1-jre	Minor	CVE-2023-2976 (7.1), CVE-2020-8908, CVE-2018-10237
protobuf-java (transitive)	3.19.4 → 3.25.3	Minor via depMgmt	CVE-2024-7254 (7.5) + 3 others
jackson-annotations (transitive)	2.9.0 → 2.14.0	Minor via depMgmt	CVE-2018-1000873 (6.5)
commons-io	2.4 → 2.15.1	Minor	CVE-2021-29425 (4.8), CVE-2024-47554
commons-lang3	3.4 → 3.18.0	Minor	CVE-2025-48924 (5.3), GHSA-j288-q9x7-2f5v

Verification: mvn clean test ✓ PASS · Grype re-scan: 73 → 1 CVE remaining

MAJOR REVIEW

mysql:mysql-connector-java:8.0.33 — GHSA-m6vm-37g8-gqvh "MySQL Connectors takeover vulnerability". Upstream fix.state=not-fixed ; no patched version available. Recommended action: migrate to com.mysql:mysql-connector-j:9.x and evaluate GPL-2.0 license compliance.

Stage 4 — Merge Gate

Check	Result	Detail
mvn clean test	PASS	All unit tests pass
OWASP Dependency-Check	N/A	NVD API rate-limited (HTTP 429); Grype used as substitute
Grype supply-chain audit	PASS	0 CRITICAL · 1 HIGH (no upstream fix = accepted residual)
CRITICAL CVEs unresolved	0	Down from 16
HIGH CVEs unresolved	1	GHSA-m6vm-37g8-gqvh — fix.state=not-fixed

Gate Verdict: PASS — ready for human review and merge.

The single remaining HIGH has fix.state=not-fixed (no upstream patch exists). A MAJOR_REVIEW tracking issue is raised. Per gate policy, a HIGH with no available fix is accepted as residual rather than blocking indefinitely. A human reviewer must approve before merge.

Health Score Trend

Metric	Before (SHA 61ed8c3)	After (fix branch)	Delta
Health Score	0 / 100	92 / 100	+92
Grade	D	A	↑↑↑
CRITICAL CVEs	16	0	-16
HIGH CVEs	51	1	-50
MEDIUM CVEs	6	0	-6

Supply-chain BLOCKs	2	0	-2
Total CVEs	73	1	-72

Reports Index

Report	File	Stage
CVE Report	depscan-reports/CVE-Report.md / .pdf	1
Risk Scoring Report	depscan-reports/Risk-Scoring-Report.md / .pdf	2
Audit Trail (this)	depscan-reports/Audit-Trail-Report.md / .pdf	5
Supply-chain SBOM	target/sbom.cdx.json	4
Supply-chain Audit JSON	depscan-supplychain-audit.json	4
Stage 1 Findings	depscan-report.json	1
Stage 2 Risk Ranking	depscan-risk-report.json	2

Demo Script

Pre-flight Checklist

- ☐ Java 17+: `java -version`
- ☐ Maven 3.8+: `mvn -version`
- ☐ Syft: `syft version`
- ☐ Gype: `gype version`
- ☐ GITHUB_TOKEN with write access to `sathiskumarperumal/dependency-supplychain-demo`
- ☐ Demo repo at SHA `61ed8c3` (`git checkout main && git reset --hard 61ed8c3`)

Rollback

```
git checkout main && git reset --hard 61ed8c3
```

Live Demo Flow (5 beats)

Beat 1 — Show the vulnerable project Open `pom.xml` ; point to `log4j-core:2.14.1` (Log4Shell) and `com.fastxml...` (typosquat).

Beat 2 — Detect

```
/risk_scoring_agent .
```

Output: 73 CVEs, health score 0/100 Grade D, Log4Shell surfaces at rank 1.

Beat 3 — Remediate

```
/depscan-pipeline . --mode full
```

Output: branch created, pom.xml patched, PR opened with full fix table.

Beat 4 — Gate

```
/pr_validation_agent <PR>
```

Output: gate PASS, 0 CRITICAL, 1 accepted HIGH.

Beat 5 — Prove

/depscan-audit-trail

Output: health score 0 → 92 (+92 Δ), 72 CVEs resolved, Grade D → A.

Stakeholder Summary

As of 2026-06-19, the `vulnerable-invoice-service` has been remediated from a critical security posture (Health Score 0/100, Grade D) to a near-clean state (Health Score 92/100, Grade A). The automated dependency & supply-chain pipeline resolved 72 CVEs — including Log4Shell (CVSS 10.0) and 15 other CRITICAL-severity vulnerabilities — and eliminated two supply-chain risks. One HIGH finding (`mysql-connector-java:8.0.33`) has no upstream patch; a MAJOR_REVIEW issue tracks the recommended migration to the official successor artifact. The remediation PR is staged for human review; no auto-merge has occurred.